Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.4 / COMPANION WORKBOOK

Measure against the STIG

DISA STIGs, SCAP scans & STIG Viewer checklists

Stage the DISA SCAP tools and content across the air gap, scan SBD-DC01 and SBD-DC02 against the Windows Server STIG with SCC, answer the manual checks in STIG Viewer checklists, and hand course 1.5 a classified findings record traced to NIST SP 800-53 controls.

MATERIALS EDITION 1.0 / COURSE 1.4

Updated 14 October 2026 · sbd-stig-scap

NAME _____ / DATE _____

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Understand STIGs, SCAP and checklists

02 Stage the DISA content across the air gap

03 Capture the pre-hardening baseline

04 Build the checklists and answer the manual checks

05 Write the findings record for hardening

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

This course measures before anything changes. It stages the Defense Information Systems Agency (DISA) Security Content Automation Protocol (SCAP) tools and content, scans SBD-DC01 and SBD-DC02 against the Security Technical Implementation Guide (STIG) with the SCAP Compliance Checker (SCC), answers the rest in STIG Viewer checklists, and writes the findings record course 1.5 hardens against. Until course 1.8 builds AdminJumpBox01, SCC runs on both controllers and STIG Viewer on SBD-DC01; course 1.8 moves both tools to AdminJumpBox01 and removes them from the controllers. Versions, paths and session folders below are examples — record yours, because course 1.5's rescan must reuse them.

Prerequisites

- ☐ Complete courses 1.1–1.3: both domain controllers healthy and replicating, DNS verified, and the domain time design in place with SBD-DC01, the PDC emulator, as the time source.
- ☐ Work at each domain controller's VM console with an authorized Domain Admin account: until course 1.8 builds AdminJumpBox01, that is where administration happens.
- ☐ Have an approved connected system and the removable-media procedure for bringing downloaded DISA content into the lab.

What this course builds

- Explain STIGs, SRGs, SCAP benchmarks, severity categories and CCIs, and what a scan can and cannot prove.
- Stage SCC, STIG Viewer, the STIGs and the DISA GPO package across the air gap with hashes verified on both sides.
- Capture a hashed SCAP baseline of both controllers and complete STIG Viewer checklists with observed evidence.
- Classify every open finding and hand course 1.5 a versioned findings record traced to NIST controls.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-DC01 — name, address, OS build	
SBD-DC02 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 25 MIN

Understand STIGs, SCAP and checklists

> **WHY THIS MATTERS** A Security Technical Implementation Guide (STIG) is DISA's configuration standard for one product, and every scan and checklist in this course measures against one. Learn how a rule is identified, rated and traced to NIST SP 800-53, which rules a scanner can read and which a person must answer, then record which STIGs apply to each controller.

In this lesson you will

- Explain how SRGs, STIGs, SCAP benchmarks and CCIs relate.
- Read a STIG rule's identifiers and severity category.
- Record which STIGs apply to each controller, and what a scan can and cannot prove.

Follow the build

1. Start with the two layers the Defense Information Systems Agency (DISA) publishes. A Security Requirements Guide (SRG) states requirements for a class of technology, such as general-purpose operating systems; a STIG turns them into checks and fixes for one product, so every STIG rule traces back to an SRG requirement.
2. Read a rule's identity and weight. Each rule has a Group ID (V-…), a Rule ID (SV-…r…_rule, where the r number is its revision), a STIG ID naming the product and check, and a severity category: CAT I (high) when exploiting the weakness directly and immediately causes loss of confidentiality, integrity or availability, CAT II (medium) when it has the potential to, and CAT III (low) when it degrades the protections against that loss.
3. Separate what a scanner can read from what a person must answer. A Security Content Automation Protocol (SCAP) benchmark is the automated part of a STIG — rules written in XCCDF with OVAL checks — which the SCAP Compliance Checker (SCC) evaluates on a host. Every other rule is a manual check, and STIG Viewer is where you build a checklist for each assessed asset, import SCC's results and record the human answers.
4. Trace rules to controls and keep a scan's limits honest. Each rule cites Control Correlation Identifiers (CCIs), DISA's single, actionable requirement statements, each mapped to a NIST SP 800-53 control, so a result can serve as control evidence. A scan shows settings on one host, at one moment, against one release: it can err or miss, it says nothing about procedures, and a pass is not an authorization.
5. Record what applies. These controllers take the Windows Server STIG (its domain controller rules included) plus the Active Directory Domain and Active Directory Forest STIGs. They also run DNS and Windows Defender Firewall, which have STIGs of their own — list those with an owner and a review date instead of dropping them silently.

Check your result

```
Get-CimInstance Win32_OperatingSystem | Select-Object CSName, Caption, Version
(Get-CimInstance Win32_ComputerSystem).DomainRole   # 5 = primary domain controller (holds
the PDC emulator role), 4 = backup domain controller
Get-WindowsFeature AD-Domain-Services, DNS | Select-Object Name, InstallState
Get-ADForest | Select-Object Name, ForestMode, Domains
```

WHAT SUCCESS LOOKS LIKE The applicability record lists each controller's operating system and roles, the STIGs that apply with the release you will measure against, and the later-scope STIGs with an owner and a review date.

Your record

Evidence to keep: Keep the applicability record: host, operating system, roles, each applicable STIG with its release, the later-scope STIGs with owner and date, and the command output behind each line.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What does a CAT I severity mean?

REMEMBER SRGs set requirements for a technology class; STIGs implement them for one product. Every rule has its identifiers, a CAT severity, and CCIs that reach a NIST control. SCC measures the benchmark, STIG Viewer holds the human answers, and neither is an authorization.

DISA · Security Content Automation Protocol (SCC and SCAP benchmarks)

DISA · SRG/STIG tools (STIG Viewer)

DISA · STIGs document library (STIGs, SRGs and the CCI list)

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 20 MIN

Stage the DISA content across the air gap

> **WHY THIS MATTERS** Everything this course and the next one use is downloaded DISA content: the SCAP Compliance Checker (SCC), STIG Viewer, the SCAP benchmarks, the STIGs and the Group Policy object (GPO) package. It crosses the boundary the way everything does here — reviewed, hashed, and carried on approved removable media.

In this lesson you will

- Identify the DISA artifacts this course and the courses after it need.
- Move them across the air gap with hashes compared on both sides.
- Record versions so scans stay comparable over time.

Follow the build

1. On an approved connected system, download from DISA's Cyber Exchange: SCC for Windows and STIG Viewer 3 with their published checksums; the SCAP benchmarks for Windows Server and for the Windows client; the Windows Server, Windows client, Active Directory Domain and Active Directory Forest STIGs and the CCI list from the document library; and the current GPO package. The Windows client content waits for the Tier 2 seat in course 1.8 and the fleet in course 1.13, and the GPO package travels now so course 1.5 imports policies from the same quarterly release as the STIGs you measure; note each file's version and release.
2. Check SCC and STIG Viewer against DISA's published checksums, then hash every file with Get-FileHash into connected-side-hashes.csv, which travels with the media, and transfer the set with the approved removable-media procedure. No live link to the lab is created for convenience.
3. In the lab, at SBD-DC01's console, copy the files into C:\Staging\DISA and the hash list into C:\Evidence\baseline\transfer, and compare every hash before opening anything; repeat on SBD-DC02 with the same full set, so its comparison is one-to-one as well, although it needs only SCC and the Windows Server benchmark. A mismatch stops the work, exactly as it will in the course 1.6 signing ceremony.
4. Install SCC on both controllers and STIG Viewer on SBD-DC01, then install the Windows Server benchmark into SCC on each controller. Until course 1.8 builds AdminJumpBox01, administration happens at the controllers' consoles; course 1.8 then moves both tools there and removes them from the controllers. Record SCC's, STIG Viewer's, each benchmark's and each STIG's version, and leave the GPO package (for course 1.5) and the Windows client content hashed in C:\Staging\DISA.

Check your result

```
Get-ChildItem C:\Staging\DISA -File | Select-Object Name, Length, LastWriteTime
New-Item -ItemType Directory C:\Evidence\baseline\transfer -Force | Out-Null
Get-ChildItem C:\Staging\DISA -File | Get-FileHash -Algorithm SHA256 | Export-Csv C:\
Evidence\baseline\transfer\lab-side-hashes.csv -NoTypeInformation
# connected-side-hashes.csv came with the media; no output means every hash matches
Compare-Object (Import-Csv C:\Evidence\baseline\transfer\connected-side-hashes.csv).Hash
(Import-Csv C:\Evidence\baseline\transfer\lab-side-hashes.csv).Hash
```

> **WHAT SUCCESS LOOKS LIKE** Every transferred file's hash matches the value recorded on the connected side on both controllers, SCC and STIG Viewer match DISA's published checksums, SCC runs on both controllers and STIG Viewer on SBD-DC01, and every version is written down.

© 2026 Secure By Design Team LLC.

Your record

Evidence to keep: Keep the transfer record in C:\Evidence\baseline\transfer on SBD-DC01: file names, versions and releases, both hash lists, the comparison result on each controller, media custody, and the date.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why hash the files on both sides of the transfer?

> **REMEMBER** SCC, STIG Viewer, the benchmarks, the STIGs and the GPO package come from DISA's Cyber Exchange. Hashes are recorded on both sides of the boundary and compared on both controllers. Versions are evidence, and the GPO package and client content wait, verified, for later courses.

DISA · Security Content Automation Protocol (SCC and SCAP benchmarks)

DISA · SRG/STIG tools (STIG Viewer)

DISA · STIGs document library (STIGs, SRGs and the CCI list)

DISA · STIG Group Policy Objects package

Microsoft · Get-FileHash

LESSON 03 / ABOUT 25 MIN

Capture the pre-hardening baseline

> **WHY THIS MATTERS** Measure before you change. A scan of the freshly built controllers shows the honest starting point, teaches what the operating system already secures by default, and becomes the before picture every later scan is compared against.

In this lesson you will

- Run a SCAP baseline scan against both domain controllers.
- Distinguish automated results from manual-review items.
- Preserve raw results as evidence with hashes and versions.

Follow the build

1. On each controller's console, run SCC locally against the Windows Server STIG benchmark staged in lesson 2. DISA content offers several mission assurance category (MAC) and confidentiality profiles: use the one your direction calls for, the same on both controllers, and record it. Each scan is a dated session; note SCC's version and the benchmark's version and release with it.
2. Open the results and read, don't just count. Note which checks already pass: the newest Windows Server release ships with defaults such as required signing on outbound SMB connections and LDAP sealing on new deployments, so part of the STIG is green before you touch anything.
3. Separate the automated results from the manual checks. SCAP answers what a scanner can read; the manual rules, and any check that returned an error rather than a pass or a fail, go to STIG Viewer for a human answer in lesson 4.
4. Store the raw results unmodified, with recorded hashes: copy each session into C:\Evidence\baseline\<host name> and hash it, then carry SBD-DC02's set to the evidence folder on SBD-DC01, where its hashes must match again. The baseline is evidence; a cleaned-up copy is a summary, not the record.

Check your result

```
# On each controller, after its SCC scan. Adapt the path to SCC's results directory.
New-Item -ItemType Directory C:\Evidence\baseline -Force | Out-Null
$session = Get-ChildItem "$env:USERPROFILE\SCC\Sessions" -Directory | Sort-Object Name |
Select-Object -Last 1
Copy-Item $session.FullName -Destination "C:\Evidence\baseline\$env:COMPUTERNAME" -Recurse
Get-ChildItem "C:\Evidence\baseline\$env:COMPUTERNAME" -Recurse -Filter '*XCCDF-
Results*.xml' | Select-Object Name, LastWriteTime
Get-ChildItem "C:\Evidence\baseline\$env:COMPUTERNAME" -Recurse -File | Get-FileHash -
Algorithm SHA256 | Export-Csv "C:\Evidence\baseline\$env:COMPUTERNAME-hashes.csv" -
NoTypeInformation
# On SBD-DC02: carry its set to SBD-DC01. Then, on SBD-DC01, no output means the copy is
identical.
Copy-Item C:\Evidence\baseline\SBD-DC02, C:\Evidence\baseline\SBD-DC02-hashes.csv -
Destination '\\SBD-DC01\C$\Evidence\baseline\' -Recurse
Compare-Object (Import-Csv C:\Evidence\baseline\SBD-DC02-hashes.csv).Hash (Get-ChildItem
C:\Evidence\baseline\SBD-DC02 -Recurse -File | Get-FileHash -Algorithm SHA256).Hash
```

> **WHAT SUCCESS LOOKS LIKE** Both controllers have a dated baseline session from the same SCC version, benchmark release and profile; the already-compliant operating system defaults are noted; and both raw result sets sit hashed in C:\Evidence\baseline on SBD-DC01, with SBD-DC02's hashes matching after the copy.

Your record

Evidence to keep: Keep the per-host result sets and their hash lists in C:\Evidence\baseline, the SCC version, benchmark release and profile, and a short note of what the operating system defaults already covered.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why scan before applying any GPO?

REMEMBER The baseline is measured, dated, and stored unmodified. Secure-by-default items are recognized, not claimed as your work. Manual checks are queued for human review.

DISA · Security Content Automation Protocol (SCC and SCAP benchmarks)

NIST · National Checklist Program (SP 800-70)

Microsoft · What's new in Windows Server (newest release)

Microsoft · Get-FileHash

LESSON 04 / ABOUT 40 MIN

Build the checklists and answer the manual checks

> **WHY THIS MATTERS** A scan answers only what it can read. In STIG Viewer on SBD-DC01, build a checklist for each controller and one for the directory, let the SCC results fill the automated rules, and answer every remaining rule with what you observed.

In this lesson you will

- Create checklists for both controllers and the directory from the staged STIG releases.
- Import the SCC results and resolve any rules that do not match.
- Answer every remaining rule with a status, finding details and comments.

Follow the build

1. On SBD-DC01, open STIG Viewer, add the staged STIGs to its library, and create three checklists: SBD-DC01 and SBD-DC02, each with the Windows Server STIG, and sbd.test with the Active Directory Domain and Active Directory Forest STIGs, whose rules assess the domain and the forest rather than one host. Fill in each controller's target data — host name, fully qualified domain name, address, and the domain controller role.
2. Import each controller's XCCDF results from C:\Evidence\baseline into its own checklist with Import XCCDF or CMRS Results, and record the import summary: rules matched, rules matched with a different revision, and rules not matched. A revision mismatch means the rule changed between the benchmark and the STIG release in the checklist, so align the releases or review those rules by hand — don't include loosely matched results blindly.
3. Work every rule still Not Reviewed — the manual checks, the whole sbd.test checklist, and anything the scan could not evaluate. Read the check text, look at the system, and set Open, Not A Finding, or Not Applicable. Write what you observed in Finding Details (the command or screen and what it showed) and the context in Comments (who reviewed, when, and any related decision).
4. Change an automated result only with evidence in Finding Details, and never lower a severity to improve the numbers: STIG Viewer requires an override reason because an assessor will read it. Save the checklists in STIG Viewer's CKLB format in C:\Evidence\baseline\checklists as SBD-DC01.cklb, SBD-DC02.cklb and sbd.test.cklb, then hash them.

Check your result

```
foreach ($t in 'SBD-DC01', 'SBD-DC02', 'sbd.test') {
  $ckl = Get-Content "C:\Evidence\baseline\checklists\$t.cklb" -Raw -Encoding UTF8 |
ConvertFrom-Json
  $ckl.stigs | Select-Object @{n='Checklist';e={$t}}, stig_name, version, release_info |
Format-Table -AutoSize
  $ckl.stigs.rules | Group-Object status | Select-Object @{n='Checklist';e={$t}}, Name,
Count | Format-Table -AutoSize   # expect no not_reviewed
}
Get-ChildItem C:\Evidence\baseline\checklists -Filter *.cklb | Get-FileHash -Algorithm
SHA256 | Export-Csv C:\Evidence\baseline\checklists-hashes.csv -NoTypeInformation
```

> **WHAT SUCCESS LOOKS LIKE** All three checklists hold the intended STIG releases and target data, each import matched by exact revision or had its mismatches reviewed, no rule is left Not Reviewed, and every manual answer carries its observation in Finding Details.

Your record

Evidence to keep: Keep the three .cklb files with their hashes, each import's summary counts, the status counts per checklist, and any severity override with its reason.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

STIG Viewer's import reports rules that matched with a different revision. What does that tell you?

> **REMEMBER** Two controller checklists and one for the directory, built from the same release as the benchmark. Automated results are imported by exact revision; a person answers the rest. Every status carries its observation, and no rule is left Not Reviewed.

DISA · SRG/STIG tools (STIG Viewer)

DISA · STIGs document library (STIGs, SRGs and the CCI list)

LESSON 05 / ABOUT 30 MIN

Write the findings record for hardening

> **WHY THIS MATTERS** A checklist full of statuses is not yet a decision. Turn the open items from all three checklists into one findings record — counted by severity, classified, owned, and traced from rule to CCI to NIST control — that course 1.5 can harden against and prove.

In this lesson you will

- Count open findings per checklist by severity category.
- Classify every open item as fix by GPO, deviation candidate, or POA&M candidate.
- Trace findings to NIST SP 800-53 controls through their CCIs and hand the record to course 1.5.

Follow the build

1. Export the open rules from all three checklists into one findings record, C:\Evidence\baseline\findings\findings-record.csv, and count them per checklist by severity. Read the CAT I items first: their exploitation directly and immediately causes loss.
2. Classify every open item with one of three values. Fix by GPO: the DISA package sets it, so course 1.5's import should close it. Deviation candidate: the setting conflicts with a design decision — for example a rule expecting the PDC emulator to synchronize with an authorized external time source, where the course 1.3 design declares and checks its own clock — and course 1.5 decides and records it. POA&M candidate: the fix lies outside Group Policy, such as the PKI server certificate the STIG expects on every domain controller, which the course 1.6 PKI issues, so it needs an owner and a planned date — the start of a Plan of Action and Milestones (POA&M) entry.
3. Trace each finding to its controls. A rule's CCIs map to NIST SP 800-53 controls in DISA's CCI list, and STIG Viewer shows them with each rule — CCI-000366, for example, is implementing the security configuration settings under CM-6 — so the record tells an assessor which control each open item weakens.
4. Write the handoff course 1.5 works from as C:\Evidence\baseline\findings\handoff.txt: SCC's version, the benchmark release and profile, the STIG releases, the GPO package release waiting hashed in C:\Staging\DISA, and where the checklists and this record live. Then hash the whole folder into C:\Evidence\baseline-manifest.csv. Course 1.5 checks that manifest, rescans with exactly those versions into C:\Evidence\hardened, updates copies of the checklists there, and closes or records every item.

Check your result

```
New-Item -ItemType Directory C:\Evidence\baseline\findings -Force | Out-Null
$rows = foreach ($t in 'SBD-DC01', 'SBD-DC02', 'sbd.test') {
  $ckl = Get-Content "C:\Evidence\baseline\checklists\$t.cklb" -Raw -Encoding UTF8 |
ConvertFrom-Json
  $ckl.stigs.rules | Where-Object status -eq 'open' | Select-Object @{n='Target';e={$t}},
@{n='GroupId';e={$_.group_id}}, @{n='StigId';e={$_.rule_version}},
@{n='Severity';e={$_.severity}}, @{n='CCIs';e={$_.ccis -join ' '}},
@{n='Title';e={$_.rule_title}}, Classification, Owner, TargetDate
}
$rows | Group-Object Target, Severity | Select-Object Name, Count
$rows | Export-Csv C:\Evidence\baseline\findings\findings-record.csv -NoTypeInformation
# After you fill in Classification, Owner and TargetDate and write handoff.txt, close the
baseline:
```

© 2026 Secure By Design Team LLC.

```
Get-ChildItem C:\Evidence\baseline -Recurse -File | Get-FileHash -Algorithm SHA256 |
Export-Csv C:\Evidence\baseline-manifest.csv -NoTypeInformation
Get-FileHash -Algorithm SHA256 C:\Evidence\baseline-manifest.csv
```

WHAT SUCCESS LOOKS LIKE The findings record lists every open rule from the three checklists with target, severity and CCIs; each carries one of the three classifications and an owner, POA&M candidates also a planned date; the counts by severity are recorded; and handoff.txt and the manifest give course 1.5 every version, path and hash it reuses.

Your record

Evidence to keep: Keep findings-record.csv, the counts by severity per checklist, the CCI-to-control notes for the open items, handoff.txt, and C:\Evidence\baseline-manifest.csv with its own hash.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

An open rule's setting is in the DISA GPO package. How is it classified?

REMEMBER Open items are counted by severity, CAT I first. Every open item is fix by GPO, deviation candidate, or POA&M candidate, with an owner. The record, the checklists, the versions and the manifest hand straight to course 1.5.

DISA · STIGs document library (STIGs, SRGs and the CCI list)

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Understand STIGs, SCAP and checklists	☐ yes	
02 Stage the DISA content across the air gap	☐ yes	
03 Capture the pre-hardening baseline	☐ yes	
04 Build the checklists and answer the manual checks	☐ yes	
05 Write the findings record for hardening	☐ yes	

Open items carried forward

Next in the learning path

That completes Measure against the STIG. Course 1.5, Harden with Group Policy, builds the organizational units, imports the DISA GPOs you staged, and rescans with the same versions to prove what changed.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.